

Threat-Based Risk Assessment (NIST SP 800-30)

26th March 2026

Overview

Conducted scoped, qualitative risk assessment on access control risks for a database server, evaluating threat scenarios, likelihood, and business impact using [NIST SP 800-30](#).

Objective

- Identify likely threat sources and events
- Assess likelihood and potential business impact
- Prioritize risks based on severity
- Recommend controls to reduce risk

System Description

- Linux-based database server (MySQL)
- 128GB memory, network-connected (IPv4)
- Stores customer, campaign, and analytics data
- Uses SSL/TLS for encrypted connections

Scope

- Focused on access control risks
- Timeframe: 3-month assessment window
- Guided by NIST SP 800-30 methodology

Key Findings

The system’s current access control posture introduces significant risk due to the likelihood of unauthorized access and data compromise.

- High risk of **data exfiltration** from external attackers
- Moderate risk of **internal disruption** from employees
- Lower likelihood but medium-impact risk of **data integrity issues** from customers

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9
Employee	Disrupt mission-critical operations	2	3	6
Customer	Alter/Delete critical information	1	2	2

Approach

Risk was assessed by identifying relevant threat sources (e.g., external attackers, employees) and mapping them to plausible threat events such as data exfiltration and operational disruption, in accordance with NIST SP 800-30.

Likelihood was based on intent, threat actor capability and system exposure, while severity reflected potential business impact, including data loss and operational disruption. Risk scores were calculated by combining likelihood and severity to prioritize the most critical threats.

Remediation Strategy

Given the database's role in supporting core marketing operations, effective access control is critical to preventing unauthorized access, data exfiltration, and operational disruption. The system stores sensitive customer, campaign, and analytics data, meaning improper access or modification could directly impact data integrity and business operations.

Access Control & Authentication

Authentication and authorization controls should be reviewed to ensure that only appropriate users can access the database and perform permitted actions. This includes validating the use of multi-factor authentication (MFA), enforcing role-based access control (least privilege), and maintaining logging and auditing mechanisms to detect and investigate suspicious activity.

Controls should also ensure that authenticated users cannot modify or delete data beyond intended permissions, reducing the risk of data integrity issues caused by application-layer or access control weaknesses.

Network Security

Database exposure should be minimized by enforcing modern TLS configurations and restricting access to trusted sources through IP allow-listing or similar network controls. Limiting network access reduces the likelihood of external threats such as unauthorized access or data exfiltration.

Critical Actions

- Validate implementation of multi-factor authentication (MFA)
- Confirm role-based access control (least privilege) is enforced
- Ensure logging and auditing mechanisms are in place and monitored

Note: As this assessment is based on likely threat scenarios rather than confirmed control gaps, the above recommendations are intended to validate and enhance existing security measures.